MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 032 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD REPORT · CUI SCOPE

CUI Sprawl Is the Scope Creep Nobody Diagrams

A correctly scoped CUI enclave still leaks through tickets, meeting transcripts, and test copies. NIST 800-171 3.1.3 closes it - stricter marking can't.

BY **MAXINE** READING TIME · 4 MIN CUI · INFORMATION-FLOW-CONTROL · SCOPING · NIST-800-171 · CMMC

An engineer pastes the tolerance from a CUI-marked drawing into a support ticket because the ticketing tool is faster than reopening the drawing file. A recurring program status call runs through a meeting platform that transcribes and stores every word by default, capturing a live discussion of a controlled requirement nobody thought to mark because nobody wrote it down. A developer copies a production dataset carrying CUI into a test environment because the test environment does not have production's access controls slowing down a Friday afternoon. None of these people violated a marking policy. Each one just did the job the way the tool made fastest, and each one left a copy of controlled content sitting outside the boundary the system security plan swears is complete. Compliance trade coverage gave the pattern a name this week that fits better than "human error" ever did: CUI sprawl.

FIELD COPY
ISSUE Nº 032
CUI

3.1.3

THE NIST 800-171 REQUIREMENT FOR INFORMATION FLOW CONTROL - THE ONE SPRAWL ACTUALLY BREAKS

170.19

THE CMMC SCOPING RULE IN 32 CFR THAT DEFINES A CUI ASSET BY FUNCTION, NOT BY NETWORK DIAGRAM

5

EVERYDAY TOOLS WHERE THIS NEWSLETTER SEES CUI SPRAWL LAND MOST OFTEN - TICKETS, MEETINGS, CHAT, GENERATIVE AI DRAFTS, AND TEST COPIES

The boundary on the diagram and the boundary in practice

Every CMMC Level 2 assessment starts from a system security plan that draws a boundary: the CUI enclave, the systems inside it, the systems excluded because they never touch controlled content. That boundary is accurate the day the SSP is written, because scoping is a design decision, not a permanent property of the network the way a subnet is a permanent property of a router. We priced that scoping decision in Enclave or Whole Network? The Scoping Decision, Priced. What that piece did not cover, because scoping happens at design time, is what happens to the boundary after the design is finished and the program starts running.

32 CFR 170.19, the CMMC scoping rule, defines a CUI asset as any system that processes, stores, or transmits CUI - a functional test, not a location on an architecture diagram. A ticketing system that stores a pasted excerpt of a drawing's dimensions passes that test the moment the excerpt lands in it, whether or not anyone updated the SSP to say so. A SaaS meeting tool that auto-transcribes a call where a controlled requirement gets discussed out loud passes it the moment the transcript is written to that vendor's storage. A test environment holding a copy of production data passes it the moment the copy exists, regardless of whether the test environment was ever meant to be in scope. This is a different failure mode from the one covered in What Actually Makes a File CUI: that piece is about whether a given file has been correctly designated. Sprawl often produces no file at all - a transcript, a ticket description, a chat message - and nobody stops to ask whether it needs a designation, because nothing about the moment looks like handling a file.

The distinction also separates sprawl from the deliberate cloud and MSP decisions covered in GCC High or Not: The External Service Provider Decision. An external service provider your program chose and evaluated is a known quantity with a shared responsibility matrix somebody read. A ticketing tool an engineer signed up for with a company email address, or a meeting platform's transcription feature that ships on by default, was never evaluated by anyone, and it sits inside your assessment boundary the moment it holds a scrap of controlled content, whether or not procurement ever heard of it.

Information flow control is the only fix that scales

A training refresh does not fix sprawl, because sprawl is not a training failure. Nobody in the three examples above was told not to paste a dimension into a ticket, sit through a transcribed call, or copy a dataset for testing - those are exactly the moves a competent employee makes to get work done efficiently, and a policy telling them to stop will be read once and ignored the first time it costs someone twenty extra minutes.

Sprawl is not what happens when someone breaks a rule. It is what happens when no rule was written for the tool they were already using.

NIST SP 800-171's requirement 3.1.3 is the control built for exactly this problem: control the flow of CUI in accordance with approved authorizations, enforced at the system level rather than trusted to memory. Applied honestly, 3.1.3 means the enclave's boundary is a technical control point, not a diagram - CUI-bearing systems route through gateways that block egress to unapproved destinations, so a ticketing tool or meeting platform that was never approved simply cannot receive controlled content, regardless of what an engineer pastes into it. That is a harder build than a policy memo, and it is also the only version of the control that survives contact with a Friday afternoon.

The inventory work underneath it is less technical and more tedious: listing every tool where CUI-adjacent work actually happens, not the tools the architecture diagram assumes are the only ones in use. Ticketing systems, meeting and transcription platforms, chat tools, generative AI drafting assistants, and test environments are the five places this newsletter sees sprawl land most often, and none of the five shows up on a network diagram drawn before any of them existed on the program. A program that reviews that list twice a year, against what employees are actually using rather than what was procured, catches sprawl while it is still a scoping question. A program that waits for an assessor to find it is answering a control failure instead. ◆

◆ SPRAWL VS. THE ESP DECISION

An external service provider your program evaluated and put under a shared responsibility matrix is a known quantity. A ticketing tool an engineer signed up for with a work email, or a transcription feature that ships on by default, was never evaluated by anyone - and it is in scope the moment it holds controlled content.